



LearnTogether@AD IT-Sicherheit und Datenschutz

Version 0.28.0 · Stand 03.10.2026

Inhalt

1. Zusammenfassung
2. Aufbau und Datenfluss
3. Verarbeitete Daten
4. Rollen und Zugriffe
5. Datenschutz
6. Mitbestimmung
7. IT-Sicherheit
8. Betrieb ohne HTTPS
9. Restrisiken und Empfehlungen
10. Entscheidungen
11. Benachrichtigungen
12. Single Sign-on: Konzept
13. Checkliste für den Start
14. Prüfung und Tests

Zusammenfassung

LearnTogether@AD ist eine Plattform für informelles Lernen im R+V-Außendienst. Kolleginnen und Kollegen bieten kurze Online-Termine in Microsoft Teams an, andere melden sich an. Dieses Papier fasst zusammen, wie die Anwendung IT-Sicherheit, Datenschutz und die Interessen der Beschäftigten schützt. Es richtet sich an IT-Sicherheit, Datenschutz, Betriebsrat und Betrieb.

Grundlage ist eine Prüfung des gesamten Quellcodes von Server und Oberfläche mit Version 0.28.0. Alle gefundenen Schwachstellen sind behoben. Zwei Rahmenbedingungen gelten bewusst: Die Anwendung setzt **kein HTTPS** voraus und verschickt **keine E-Mails**.

Prüfbereich	Ergebnis
Anmeldung und Sitzungen	Sichere Passwort-Hashes, zufälliges Startpasswort, Schutz vor Rate-Angriffen, serverseitig beendbare Sitzungen
Angriffe über den Browser	Schutz vor fremden Formularen (CSRF), eingeschleusten Skripten (XSS) und Einbettung (Clickjacking), strenge Sicherheits-Header
Uploads und Eingaben	Prüfung auf dem Server, Bilder mit Inhaltsprüfung, Beschreibungen über Positivliste bereinigt
Datenschutz	Datensparsam, privat voreingestellt, Auskunft und Löschung per Klick, feste Lösch- und Anonymisierungsfristen
Mitbestimmung	Keine Ranglisten, keine Einzelbewertungen, keine Anmeldezeiten je Person, Abzeichen und Profil freiwillig
Betrieb ohne HTTPS	Restrisiko: Passwörter und Sitzungen gehen unverschlüsselt durchs Netz. Ausgleich: nur internes Netz, Zugriff im IIS begrenzen

Aufbau und Datenfluss

- **Bestandteile:** eine statische Webseite (`index.html`) und ein ASP.NET-Handler (`AppData/api.ashx`) auf dem IIS. Es gibt keine Datenbank, keinen Node.js-Dienst und keine Zusatzsoftware.
- **Datenablage:** JSON-Dateien und Bilder im Ordner `AppData\Data` auf dem Server. Der Ordner ist über das Web nicht abrufbar, doppelt abgesichert über `web.config`.
- **Keine externen Dienste:** Keine Tracker, kein Analyse-Werkzeug, kein CDN, keine Fremdschriften. Schriften, Logos und Bilder liegen auf dem eigenen Server. Die Sicherheits-Header verbieten Verbindungen zu fremden Servern.
- **Keine Fremdbibliotheken:** Oberfläche und Server kommen ohne Pakete Dritter aus. Damit entfällt das Risiko über fremde Abhängigkeiten.
- **Microsoft Teams:** Die Anwendung speichert nur den Link zur Besprechung. Er ist nur für angemeldete Teilnehmende sichtbar. Die Besprechung selbst läuft vollständig in Teams.
- **Cookies:** Es gibt genau ein Cookie, das Sitzungs-Cookie. Es ist technisch notwendig.

Verarbeitete Daten

Daten	Zweck	Sichtbar für	Speicherdauer
Benutzername	Anzeige auf Kacheln und Listen	alle	bis zur Löschung des Kontos
Vor- und Nachname, XV-Nummer, E-Mail-Adresse	Zuordnung, Nachweis, Kontakt durch die Administration	die Person selbst, Administration; E-Mail nur nach Freigabe auch andere	bis zur Löschung des Kontos
Passwort	Anmeldung	niemand (nur als Hash gespeichert)	bis zur Löschung des Kontos
Anmeldungen zu Veranstaltungen	Platzvergabe, Teams-Link, Nachweis	die Person selbst; Administration nur bei dienstlichen Veranstaltungen, bei privaten nur die Anzahl; Anbietende sehen nur Benutzernamen	dienstlich 5 Jahre, privat 12 Monate nach der Veranstaltung, dann anonymisiert
Eigene Veranstaltungen	Katalog, Organisation	alle (ohne Teams-Link)	dienstlich 5 Jahre, privat 12 Monate nach der Veranstaltung, dann anonymisiert
Abzeichen und Expertenstatus	Anerkennung	die Person selbst; andere nur nach Zustimmung	berechnet, nicht gespeichert
Einstellung Browser-Benachrichtigung	Hinweis auf neue Mitteilungen	nur im eigenen Browser gespeichert	bis zum Ausschalten
Bewertungen (1 bis 5 Sterne)	Rückmeldung an Anbietende	niemand einzeln; Anbietende sehen ihren Durchschnitt ab 3 Bewertungen; Administration nur zusammengefasst nach	mit der Anmeldung, danach anonym

		Monat, Bereich und Thema	
Profil, Beschreibung, Profilbild	freiwillige Vorstellung	nur nach Freigabe	bis zur Änderung oder Löschung
Letzte Anmeldung	automatische Löschung inaktiver Konten	niemand einzeln; Administration nur als Gesamtzahl	bis zur nächsten Anmeldung
Admin-Protokoll	Nachvollziehbarkeit von Änderungen durch die Administration	Betrieb auf dem Server	12 Monate

Die Anwendung erfasst keine Arbeitszeit, keine Inhalte aus Teams, keine Standorte und keine Geräte-Merkmale. IP-Adressen nutzt sie nur kurz im Arbeitsspeicher, um Fehlversuche zu bremsen. Sie speichert sie nicht. Die Zugriffsprotokolle des IIS sind davon unabhängig und folgen den Regeln des Serverbetriebs.

Rollen und Zugriffe

Rolle	Darf	Sieht
Ohne Anmeldung	Katalog ansehen	Veranstaltungen und Benutzernamen, keine Teams-Links
Nutzende	Anmelden, abmelden, bewerten, Veranstaltungen anbieten, bearbeiten und absagen, Profil pflegen, Daten herunterladen, Konto löschen	Eigene Daten; bei eigenen Veranstaltungen die Benutzernamen der Teilnehmenden und den Durchschnitt ab 3 Bewertungen
Administration	Veranstaltungen und Anmeldungen verwalten, Passwörter zurücksetzen, Konten sperren und löschen, Texte, Themen und Einstellungen pflegen	Kontodaten aller Personen, Teilnehmendenlisten dienstlicher Veranstaltungen, bei privaten nur die Anzahl; Sterne nur zusammengefasst ohne Bezug zu Anbietenden; keine Anmeldezeiten je Person
Hauptadministration	Zusätzlich Admin-Rechte vergeben und entziehen, Admin-Konten löschen	wie Administration
Betrieb (Server)	Installation, Datensicherung	Dateien in AppData\Data

Die Rechte prüft immer der Server. Eine veränderte Oberfläche verschafft keine weiteren Rechte.

Datenschutz

Grundsätze

- **Datensparsam:** Nur Daten, die für Anmeldung, Organisation und den späteren Nachweis nötig sind.
- **Privat voreingestellt:** Profile sind nicht öffentlich, Abzeichen nur für die Person selbst sichtbar. Jede weitere Angabe geben Nutzende einzeln frei.
- **Pseudonym im Alltag:** Andere sehen nur den frei gewählten Benutzernamen. Echte Namen sieht nur die Administration.
- **Zweckbindung:** Die Daten dienen nur Organisation und Nachweis. Die Anwendung gibt nichts an andere Systeme weiter.

- **Freiwillig:** Teilnahme, Angebot, Bewertung, Profil, Profilbild und Abzeichen sind freiwillig.

Rechte der Beschäftigten direkt in der Anwendung

Recht	Umsetzung
Auskunft und Datenübertragbarkeit (Art. 15 und 20 DSGVO)	Profil > Konto > Meine Daten herunterladen: alle Daten zum Konto als JSON-Datei
Berichtigung (Art. 16 DSGVO)	Name, XV-Nummer und E-Mail-Adresse selbst ändern
Löschung (Art. 17 DSGVO)	Profil > Konto > Konto löschen, sofort und ohne Umweg über die Administration
Einschränkung der Sichtbarkeit	Profil, Profilbild, E-Mail-Adresse, Bewertung, Expertenstatus und Abzeichen einzeln ein- und ausschalten

Fristen

- Dienstliche Veranstaltungen und Anmeldungen werden **5 Jahre** nach dem Ende automatisch anonymisiert. Die Frist folgt der Nachweispflicht der IDD.
- Private Veranstaltungen und Anmeldungen werden schon nach **12 Monaten** anonymisiert. Für sie gibt es keinen Nachweiszweck.
- Konten ohne Anmeldung seit **24 Monaten** löscht die Anwendung automatisch.
- Das Admin-Protokoll bleibt **12 Monate**. Das Fehlerprotokoll ist auf 2 MB begrenzt und enthält keine Passwörter.
- Bei einer Löschung werden Kontaktdaten, Profilbild und Mitteilungen sofort entfernt. Künftige eigene Veranstaltungen werden abgesagt. Vergangene Teilnahmen bleiben nur anonym für die Statistik.

Vor dem Start mit Datenschutz zu klären

- Rechtsgrundlage und Zweckbeschreibung festlegen und das Verzeichnis der Verarbeitungstätigkeiten ergänzen.
- Datenschutzhinweis für Beschäftigte bereitstellen, zum Beispiel im Handbuch oder im Intranet.
- Aufbewahrung der Datensicherungen mit den Fristen der Anwendung abstimmen.
- Prüfen, ob eine Datenschutz-Folgenabschätzung nötig ist. Wegen des kleinen Datenumfangs und der Schutzmaßnahmen ist eher keine zu erwarten.

Mitbestimmung

Die Anwendung verarbeitet Daten von Beschäftigten. Sie unterliegt deshalb der Mitbestimmung nach § 87 Abs. 1 Nr. 6 BetrVG. Eine Leistungs- oder Verhaltenskontrolle ist technisch ausgeschlossen, soweit die Funktionen es zulassen:

Thema	Technische Ausgestaltung
Bewertungen	Anonym. Niemand sieht, wer wie bewertet hat. Die anbietende Person sieht ihren Durchschnitt ab drei Bewertungen. Die Administration sieht keine Sterne je Veranstaltung oder Person, nur Werte je Monat, Bereich und Thema, und erst ab drei verschiedenen Anbietenden.
Ranglisten	Gibt es nicht. Die Statistik zeigt nur zusammengefasste Werte, zum Beispiel je Monat, Thema oder Format.
Aktivität	Die Administration sieht keine Anmeldezeiten und keine Teilnahmen je Person. Die Statistik zeigt nur, wie viele Konten in einem Zeitraum aktiv waren.
Abzeichen und Expertenstatus	Richten sich nach der Zahl angebotener Veranstaltungen und dienen der Anerkennung. Andere sehen sie erst nach Zustimmung der Person (Opt-in), widerruflich.
Teilnehmendenlisten	Anbietende sehen nur Benutzernamen. Echte Namen sieht die Administration nur bei dienstlichen Veranstaltungen, für Organisation und späteren Nachweis. Wer an privaten Veranstaltungen teilnimmt, sieht die Administration nicht.
Schnittstellen	Keine. Keine Übergabe an Personal-, Zeit- oder Vertriebssysteme.
Arbeitszeit	Wird nicht erfasst. Teilnehmende an dienstlichen Sessions stempeln sich selbst ein und aus.

Vorschlag für eine Vereinbarung: Zweck, Datenarten, Rollen und Fristen wie in diesem Papier festhalten. Dazu ein Verbot, Daten der Anwendung zur Leistungs- oder Verhaltensbeurteilung zu nutzen. Änderungen an Auswertungen nur nach Abstimmung.

IT-Sicherheit

Bereich	Maßnahme
Passwörter	PBKDF2-SHA256 mit 100.000 Runden und eigenem Salt. Mindestens 10 Zeichen, bekannte Passwörter und Teile von Benutzername oder E-Mail werden abgelehnt.
Startpasswort	Zufällig erzeugt, nur auf dem Server in einer Datei lesbar, nach der ersten Änderung automatisch gelöscht. Kein festes Standardpasswort auf dem Server.
Fehlversuche	5 Fehlversuche je Benutzername, 50 je IP-Adresse, dann 5 Minuten Sperre. Gleiche Antwortzeit für bekannte und unbekannte Benutzernamen.
Vorläufige Passwörter	Bis zur Änderung erlaubt der Server nur Profil und Passwortänderung.
Sitzungen	Signiertes Cookie (HMAC-SHA256), HttpOnly, SameSite=Strict, Secure bei HTTPS. Feste Dauer 8 Stunden. Der Server führt die Sitzungen je Konto. Abmelden, Sperren und Passwortwechsel beenden sie sofort.
Fremde Formulare (CSRF)	Schreiben nur per POST mit Pflicht-Header. Andere Websites können ihn nicht setzen. Das Cookie geht nicht an fremde Seiten.
Eingeschleuste Skripte (XSS)	Ausgabe als Text. Beschreibungen werden auf dem Server und im Browser über eine Positivliste bereinigt. Links nur mit http, https oder mailto.
Sicherheits-Header	Content-Security-Policy ohne fremde Quellen, X-Frame-Options, X-Content-Type-Options, Referrer-Policy, Permissions-Policy, Cross-Origin-Opener-Policy. Die Server-Kennung X-Powered-By entfällt.
Uploads	Nur JPEG, PNG und WebP bis 2 MB. Der Server prüft den Dateiinhalt. Ablage außerhalb des Web-Zugriffs, Auslieferung nur über den Handler.
Eingaben	Jede Eingabe prüft der Server: Längen, Formate, Zeitfenster, Teams-Links nur zu Microsoft-Teams-Adressen.
Zwischenspeicher	Antworten mit persönlichen Daten tragen no-store und bleiben nicht im Browser-Cache.

Fehler	Nutzende sehen keine technischen Details. Der Selbsttest mit Pfaden und Benutzernamen ist nur direkt auf dem Server abrufbar.
Protokoll	Änderungen der Administration mit Zeit, Benutzername, Aktion und Datensatz-Kennung. Keine Inhalte, keine Passwörter.
Testdaten	Testkonten haben ein bekanntes Passwort. Die Administration zeigt einen Hinweis, solange Testdaten geladen sind.

Betrieb ohne HTTPS

Die Anwendung läuft auch über HTTP. Dann gehen Passwörter und Sitzungs-Cookies unverschlüsselt durchs Netz. Wer den Netzverkehr mitlesen kann, könnte sie abgreifen. Dieses Restrisiko lässt sich nur mit HTTPS vollständig beseitigen.

Ausgleichende Maßnahme	Wirkung
Nur im internen Netz betreiben, nicht aus dem Internet erreichbar	Mitlesen ist nur im Firmennetz möglich
Zugriff im IIS auf Firmennetz und VPN begrenzen (IP-Adressen und Domänen einschränken)	Fremde Rechner erreichen die Anwendung nicht
Eigenes Passwort nur für diese Anwendung	Ein abgegriffenes Passwort öffnet keine anderen Systeme
Sitzungen mit fester Dauer und Abmeldung auf dem Server	Ein abgegriffenes Cookie verliert schnell seinen Wert
Hinweis in der Administration bei Betrieb ohne HTTPS	Das Risiko bleibt sichtbar

Empfehlung: HTTPS mit einem Zertifikat der internen Zertifizierungsstelle einrichten. Die Anwendung erkennt HTTPS selbst und setzt dann das Secure-Merkmal am Cookie. Eine Änderung am Code ist nicht nötig.

Restrisiken und Empfehlungen

Restrisiko	Einschätzung	Empfehlung
Unverschlüsselte Übertragung ohne HTTPS	mittel, im internen Netz gering	HTTPS einrichten, bis dahin Zugriff begrenzen
Offene Registrierung für alle, die die Seite erreichen	gering im internen Netz	Zugriff begrenzen; später Anmeldung über das Unternehmensverzeichnis prüfen
Keine Prüfung der Identität bei der Registrierung: jemand könnte eine fremde XV-Nummer angeben	gering, fällt spätestens der betroffenen Person auf	Administration löscht solche Konten; optional Freischaltung neuer Konten durch die Administration oder Anmeldung über das Unternehmensverzeichnis
Keine Zwei-Faktor-Anmeldung	gering, da wenig schutzbedürftige Daten	Admin-Konten mit starken Passwörtern und wenigen Personen
Daten unverschlüsselt im Dateisystem	gering bei korrekten Rechten	Rechte auf AppData\Data nur für Anwendungspool und Betrieb, Laufwerksverschlüsselung des Servers
Sperren nach Fehlversuchen liegen im Arbeitsspeicher	gering	Ein Neustart des Anwendungspools hebt sie auf. Dazu keine automatischen Neustarts in kurzen Abständen
Administration sieht echte Namen der Teilnehmenden dienstlicher Veranstaltungen	gewollt, für Organisation und Nachweis	Wenige benannte Personen, Zweckbindung in der Vereinbarung
Rückschluss auf einzelne Bewertungen über die Änderung des Durchschnitts	sehr gering	Durchschnitt erst ab drei Bewertungen; Anbietende wissen nicht, wer wann bewertet
Demo-Version im Browser	nur für Tests	Keine echten Daten in die Demo eingeben

Entscheidungen

Frage	Stand
Wie lange bleiben Daten privater Veranstaltungen gespeichert?	Entschieden: 12 Monate. Dienstliche Veranstaltungen 5 Jahre wegen der IDD.
Sind Abzeichen ohne eigene Entscheidung sichtbar?	Entschieden: nein. Abzeichen und Rakete erscheinen erst nach Zustimmung.
Werden neue Konten geprüft?	Offen. Für den Pilot reicht die Selbstregistrierung. Ziel ist die Anmeldung über das Unternehmenskonto (siehe Single Sign-on).

Benachrichtigungen

Die Anwendung verschickt keine E-Mails. Bei Absage oder Termin-Update erhalten Angemeldete eine Mitteilung in der Anwendung. Sie erscheint in der Navigation und auf der Startseite. Die Kalenderdatei trägt einen Änderungsstand und aktualisiert den vorhandenen Eintrag.

Weg	Bewertung
Browser-Benachrichtigung bei geöffnetem Tab	Umgesetzt. Kein externer Dienst, die Anwendung fragt alle drei Minuten nach. Setzt HTTPS voraus, sonst bleibt der Schalter aus.
Web-Push aufs Handy	Nicht empfohlen. Braucht HTTPS, einen einmaligen Aufruf auf dem Handy und einen externen Push-Dienst von Google, Apple oder Mozilla. Ohne vorherigen Aufruf auf dem Handy ist Push technisch unmöglich.
Microsoft Teams (Aktivitätsfeed oder Chat)	Empfohlen als nächster Schritt. Erreicht das Handy über die vorhandene Teams-App. Setzt SSO mit Microsoft Entra ID und eine Freigabe der IT für Microsoft Graph voraus.

Single Sign-on: Konzept

Ziel ist die Anmeldung mit dem Unternehmenskonto. Dann entfallen eigene Passwörter, die Registrierung und das Risiko fremder XV-Nummern. Vorbereitet sind Felder am Konto für die Kennung im Verzeichnis und die Art der Anmeldung. Die Sitzung entsteht an einer Stelle im Server, die auch SSO nutzt.

	Weg A: Windows-Anmeldung am IIS	Weg B: Microsoft Entra ID (OpenID Connect)
Funktionsweise	IIS prüft das Windows-Konto (Kerberos), nur für eine Anmeldeseite	Weiterleitung zur Microsoft-Anmeldung, Rückgabe eines signierten Tokens
Voraussetzungen	Geräte in der Domäne oder per VPN, Windows-Authentifizierung am IIS	HTTPS, App-Registrierung in Entra ID, ausgehende Verbindung des Servers zu Microsoft
Ohne HTTPS möglich	Ja, das Passwort geht nicht übers Netz. Das Sitzungs-Cookie bleibt ungeschützt	Nein
Zusatznutzen	Schnell im Intranet umsetzbar	Grundlage für Teams-Benachrichtigungen und Zugriff von unterwegs

Übergang: Beim ersten SSO-Anmelden verknüpft die Person ihr bestehendes Konto einmalig mit dem alten Passwort. Neue Personen erhalten ein Konto mit Name und E-Mail-Adresse aus dem Verzeichnis. Die XV-Nummer kommt aus dem Verzeichnis, falls dort gepflegt. Ein lokales Notfall-Konto der Hauptadministration bleibt. Aus dem Verzeichnis übernimmt die Anwendung nur Name, E-Mail-Adresse und Kennung.

Empfehlung: Weg B, sobald HTTPS steht, weil er Teams-Benachrichtigungen ermöglicht. Weg A als schnelle Zwischenlösung im Intranet.

Checkliste für den Start

1. Anwendung nur im internen Netz bereitstellen, Zugriff im IIS auf Firmennetz und VPN begrenzen.
2. HTTPS mit internem Zertifikat einrichten, sobald möglich.
3. Rechte auf AppData\Data nur für den Anwendungspool und das Betriebsteam vergeben.
4. Startpasswort aus AppData\Data\admin-startpasswort.txt nutzen und sofort ändern.
5. Testdaten entfernen (System > Testdaten).
6. Admin-Rechte nur an wenige benannte Personen aus VH-VP-TV vergeben.
7. Datensicherung von AppData\Data einrichten, Aufbewahrung mit den Fristen abstimmen.
8. Datenschutzhinweis veröffentlichen und das Verzeichnis der Verarbeitungstätigkeiten ergänzen.
9. Vereinbarung mit dem Betriebsrat abschließen.

10. AppData\selftest.ashx nach der Einrichtung bei Bedarf löschen.

Prüfung und Tests

Die Prüfung umfasste alle Endpunkte des Servers, die Oberfläche, die IIS-Konfiguration und den Selbsttest. Automatische Tests im Browser prüfen bei jedem Stand die Funktionen und die Schutzmaßnahmen. Sie laufen gegen den Server und gegen die Demo-Version. Geprüft wird unter anderem:

- Das alte Standardpasswort gilt auf dem Server nicht. Die Datei mit dem Startpasswort verschwindet nach der Änderung.
- Ein kopiertes Sitzungs-Cookie ist nach dem Abmelden wertlos.
- Schreibende Aufrufe per GET werden abgelehnt.
- Ein Skript, getarnt als Bild, wird beim Hochladen abgelehnt.
- Antworten tragen no-store.
- Die Administration erhält keine Einzelbewertungen, keine Sterne je Veranstaltung, keine Anmeldezeiten und keine Teilnahmen je Person.
- Bei privaten Veranstaltungen erhält die Administration keine Namen der Teilnehmenden.
- Ändert die anbietende Person Termin oder Teams-Link, erhalten Angemeldete ein Termin-Update.
- Neue Konten zeigen ihr Abzeichen erst nach Zustimmung.
- Durchschnittswerte erscheinen erst ab drei Bewertungen.
- Ausgeblendete Abzeichen erscheinen nirgends.
- Gelöschte Konten können sich nicht mehr anmelden.
- Konten mit vorläufigem Passwort können nur das Passwort ändern.